</> codigo.py

Analise o arquivo em anexo passo a passo e determine ao final: este arquivo é benigno ou é um malware?

Worked for 1s >

Este arquivo é malware (mais precisamente, um dropper/instalador malicioso de extensão de navegador).

1. **Notificação externa (C2/beacon)**

   A função `notificar_instalacao` envia um POST para `https://ntfy.sh/crimeorganizado000000000000caiunoob` com a mensagem “Extensão X instalada para o usuário Y”.

   Isso é um canal de notificação de sucesso típico de malware (o tópico ntfy tem nome claramente associado a atividade criminosa). Não existe em software legítimo.

2. **Força o fechamento do Chrome**

   `fechar_chrome()` usa `psutil` para enumerar e terminar todos os processos cujo nome contém “chrome”. Isso é necessário para poder alterar os arquivos de preferências sem que o Chrome os sobrescreva ou detecte a mudança em tempo real.

3. **Download de payload de fonte não confiável**

   Baixa `https://antiddos-protection.net/___________/chrome_extension.zip`, extrai em um diretório temporário e usa o caminho extraído.

   O domínio e o caminho oculto (`___________`) são indicadores clássicos de distribuição de malware/PUP. A extensão não vem da Chrome Web Store.

4. **Geração de Extension ID e falsificação de metadados**

   Calcula o ID da extensão a partir do caminho (método padrão do Chromium para extensões unpacked).

   Cria um JSON de configuração da extensão com:

   - `location: 4` (load-unpacked / sideload)
   - `from_webstore: false`
   - Permissões amplas: `cookies`, `storage`, `tabs`, `scripting`, `downloads` + `explicit_host: ["<all_urls>"]`
   - `incognito: true`

- Timestamps de instalação falsificados

5. **Bypass da proteção de integridade do Chrome (Secure Preferences)**

   Este é o núcleo da técnica maliciosa:

   - Lê `C:\Users\<user>\AppData\Local\Google\Chrome\User Data\Default\Secure Preferences`
   - Injeta a entrada da extensão em `extensions.settings.<id>`
   - Usa o **seed hardcoded e conhecido** do Chrome (o mesmo blob de 64 bytes documentado em pesquisas de segurança e em HackTricks/papers desde ~2020):

     ```
     text
     b'\xe7H\xf36\xd8^\xa5\xf9\xdc\xdf%\xd8\xf3G\xa6[L\xdffv\x00\xf0-\xf6rJ*\xf
     ```

   - Calcula HMACs válidos (`calculateHMAC` , `calculate_chrome_dev_mac` , `calc_supermac`) usando o SID do usuário + path + valor serializado.
   - Ativa `extensions.ui.developer_mode = True` e gera o MAC correspondente.
   - Reescreve o arquivo com os novos MACs e o `super_mac` .

   Essa técnica (HMAC forgery em Secure Preferences) é amplamente documentada como método de **instalação silenciosa de extensões maliciosas** após o comprometimento da máquina. É usada por adware, info-stealers e loaders de browser extension. O Chrome considera isso tampering; malware que gera MACs corretos contorna a proteção.

6. **Execução**

   O bloco `if __name__ == "__main__":` chama `add_extension()` imediatamente. O script é autônomo e projetado para rodar com privilégios do usuário (usa `win32api` / `win32security` para obter SID e nome de usuário).

Não é código benigno, de teste legítimo ou ferramenta de administração.

É um **instalador silencioso de extensão maliciosa** que:

- Fecha o navegador à força
- Baixa um payload de fonte suspeita
- Forja as assinaturas de integridade do Chrome
- Instala a extensão com permissões de alto risco (acesso a cookies + todas as URLs)
- Notifica um canal externo associado a “crime organizado”

Essa combinação é caracteristicamente malware (técnica de post-exploitation / persistence via browser extension). Não execute este arquivo.

Qual é a categoria principal deste malware?

Worked for 6s >

A categoria principal é Dropper (instalador/dropper de extensão maliciosa de navegador).

- **Dropper / Loader**: O script em si não executa o roubo de dados ou a atividade maliciosa principal. Ele apenas prepara o ambiente (fecha o Chrome), baixa a extensão de uma fonte externa, forja as assinaturas HMAC do arquivo `Secure Preferences` e instala a extensão de forma silenciosa. Depois notifica o sucesso. Isso é o comportamento clássico de um *dropper*.
- A extensão instalada (com permissões amplas de `cookies`, `tabs`, `scripting` e `<all_urls>`) é o payload real, que tipicamente atua como:
  - Infostealer (roubo de cookies/sessões)
  - Man-in-the-Browser
  - Ou adware/browser hijacker

Em relatórios de antivírus e taxonomias comuns (MITRE ATT&CK T1176 – Browser Extensions + T1105 – Ingress Tool Transfer), amostras com esse padrão de falsificação de HMAC + sideload silencioso de extensão costumam ser classificadas como **Trojan** na categoria geral, com a subcategoria específica de **Dropper de Extensão de Navegador** ou **Chrome Extension Dropper**.

Resumo:

Categoria principal → Dropper

Família/comportamento → Instalador silencioso de extensão maliciosa (Trojan).

↘ Qual é a categoria mais específica?

↘ Explique o mecanismo HMAC

↘ Como detectar esse malware